

Task 1 - Cybersecurity Basics & Attack Surface

1. Introduction
2. CIA Triads
3. Types of Attackers
4. Attack Surfaces
5. OWASP Top 10 Overview
6. Mapping daily apps to attack surface
7. Data Flow and attack points
8. Conclusion / Summary

What is Cyber Security

Cybersecurity is the practice of protecting digital devices, networks, systems, and data from malicious attacks, unauthorized access, damage, or theft. It ensures the confidentiality, integrity, and availability of information by using a combination of technology, processes, and people to defend against threats like malware, phishing, ransomware, and cyber espionage.

CIA Triad meaning

The CIA Triad is a foundational model in information security that outlines three core principles: Confidentiality, Integrity, and Availability. These principles guide organizations in protecting their data and systems.

Confidentiality

Confidentiality in cybersecurity refers to the protection of sensitive information from unauthorized access, use, disclosure, or modification. It ensures that data is accessible only to individuals or systems with proper authorization, maintaining privacy and trust.

- Access Control
- Encryption
- Authentication & Authorization
- Compliance & Trust

Integrity

Integrity in cybersecurity refers to ensuring that data and systems remain accurate, complete, consistent, and unaltered by unauthorized or unintended changes throughout their lifecycle.

Examples:

- Bank transaction amount should not change
- Hashing used in file verification
- Digital signatures

Availability

Availability in cybersecurity ensures that authorized users can access systems, data, and services timely and reliably when needed, regardless of disruptions like cyberattacks, hardware failures, or natural disasters.

Examples:

- DoS / DDoS makes websites down
- Banking app should be available 24/7
- Server uptime

CIA	Meaning	Example Attack
Confidentiality	data privacy	data leak
Integrity	data accuracy	tampering
Availability	system uptime	DDoS

Types of hackers

- **White Hat Hackers:** Also known as ethical hackers, they are authorized to test systems for vulnerabilities to improve security. They work legally with organizations, often as penetration testers or security consultants, and aim to protect data and networks.
- **Black Hat Hackers:** These are malicious cybercriminals who break into systems illegally for personal gain, such as stealing data, deploying ransomware, or causing disruption. Their actions are illegal and punishable by law.
- **Gray Hat Hackers:** Operating in a moral gray area, they may hack without permission to expose vulnerabilities but without malicious intent. While they might report flaws, their unauthorized access can still be illegal.

Script Kiddies

- Use ready-made tools (no deep knowledge)

- Example: using LOIC tool for DDoS

Insiders

- Employees misusing access
- Example: leaking company data

Hacktivists

- Attack for political/social purpose
- Example: defacing govt websites

Nation-State actors

- Government-backed advanced attackers
- Example: cyber espionage

Attack Surfaces

All possible points where attacker can enter / exploit.

1) Web Application Attack Surface

Web Application Attack Surface refers to the total set of entry points an attacker could exploit to compromise a web application.

Examples:

- Login page
- Search bar
- Forms
- File upload

Attacks:

- SQL Injection
- XSS
- CSRF

2) Mobile App Attack Surface

The mobile app attack surface refers to all potential entry points and vulnerabilities in a mobile application or device that attackers can exploit to gain unauthorized access, steal data, or compromise systems.

Examples:

- APK reverse engineering
- Stored tokens

- insecure storage
- permissions misuse

Attacks:

- Data leakage
- insecure storage

3) *API Attack Surface*

API Attack Surface refers to the total set of all potential entry points in an organization's APIs that malicious actors can exploit to gain unauthorized access, steal data, or disrupt services.

Examples:

- /login API
- /payment API
- /admin API

Attacks:

- Broken auth
- IDOR
- rate-limit bypass

4) *Network Attack Surface*

Network Attack Surface refers to the total sum of all vulnerabilities and potential entry points that malicious actors can exploit to gain unauthorized access to a network. It encompasses all components of an organization's digital infrastructure, including network devices (routers, switches, firewalls), servers, endpoints (laptops, mobile devices), applications, APIs, cloud services, and external connections like third-party integrations.

Examples:

- Open ports (22, 80, 443)
- Wi-Fi
- routers

Attacks:

- Port scanning
- MITM
- brute force

5) *Cloud Infrastructure Attack Surface*

Cloud Infrastructure Attack Surface refers to the total set of potential entry points in a cloud environment that attackers can exploit to gain unauthorized access to data, systems, or

infrastructure. As organizations increasingly adopt cloud computing, this attack surface has expanded dramatically due to the dynamic nature of cloud environments, the proliferation of cloud services (IaaS, PaaS, SaaS), and the integration of technologies like AI and APIs.

Examples:

- S3 bucket misconfiguration
- exposed keys
- IAM issues

Attacks:

- Cloud data leaks
- privilege escalation

OWASP Top 10 list

The OWASP Top 10:2025 is the latest edition of the widely recognized web application security risk list, published by the Open Worldwide Application Security Project (OWASP). It identifies the ten most critical web application security risks based on data from real-world attacks, testing, and community input.

- Broken Access Control
- Cryptographic Failures
- Injection
- Insecure Design
- Security Misconfiguration
- Vulnerable and Outdated Components
- Identification and Authentication Failures
- Software and Data Integrity Failures
- Security Logging and Monitoring Failures
- Server-Side Request Forgery (SSRF)

Map daily apps to attack surfaces

Gmail / Email:

- Attack surface: phishing emails, login page
- Possible attack: credential theft, malware attachments

WhatsApp:

- Attack surface: messages, media files, links
- attack: malicious links, social engineering

Banking App:

- Attack surface: login, APIs, payment gateway, server DB
- attacks: credential stuffing, MITM, fraud

App	Attack Surface	Possible Attack
Email	Inbox + login	Phishing
WhatsApp	Links/media	Malware link
Banking	API/payment	fraud + IDOR

Document Data Flow

Example: Online Banking Fund Transfer

1) User (Customer)

The user opens the banking app and enters **login credentials + transfer details** (receiver account, amount, UPI pin/OTP).

Example:

Hari enters: *Account no: 1234, Amount: ₹5000, OTP: 726191*

2) Application (Mobile/Web App)

The banking app collects the user input and sends it securely to the bank's backend using HTTPS requests (API calls).

Example:

App sends request like:

POST /transfer

with details: sender, receiver, amount, OTP

3) Server (Backend / Bank System)

The bank server verifies the OTP, checks balance, checks fraud rules, and decides whether transaction is valid or not.

Example:

Server checks:

- OTP correct
 - Enough balance
 - Receiver account valid
- Then approves transaction.

4) Database (Bank Records)

Database stores all details permanently:

- transaction history
- account balance update

- logs for auditing

Example:

Database updates:

- sender balance: ₹20,000 → ₹15,000
- receiver balance: ₹5,000 → ₹10,000
- transaction entry saved

Summary

This task helped me understand cybersecurity fundamentals like CIA triad, attacker types, and how attack surfaces exist in web, mobile, API, network, and cloud environments...